SIMATS ENGINEERING ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1436**

COURSE OUTCOME COVERED

CO2: Execute foot printing in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis

Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I Ch.Tharunika Reddy(192324307) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Ch.Tharunika Reddy

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is wellorganized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1: Network Scan Report Analysis Using Nmap

1. Introduction

Network scanning is an important activity in ethical hacking used to identify active hosts, open ports, running services, and potential security vulnerabilities. Nmap (Network Mapper) is a widely used network scanning tool that helps security analysts understand the attack surface of a target system.

In this scenario, the target system has the IP address 192.168.1.10. The Nmap report identifies three open ports: HTTP (80), SSH (22), and MySQL (3306). It also reveals the operating system and service versions. These findings help security professionals identify unnecessary services, outdated software, weak configurations, and possible entry points for attackers.

2. Analysis of the Nmap Report

Port	Service	Purpose	Potential security concern
80	HTTP	Provides web pages and web application services	Unencrypted communication, web application vulnerabilities
22	SSH	Provides secure remote administration	Weak passwords, compromised credentials, insecure configuration
3306	MySQL	Provides database connectivity	Unauthorized database access, data leakage, excessive privileges
OS and service versions	System identification	Helps determine software and platform details	Version-specific vulnerabilities and targeted attacks

3. Security Risks Associated with HTTP (Port 80)

HTTP (Hypertext Transfer Protocol) is commonly used to deliver web pages between a web server and a user's browser. Port 80 is the default port for HTTP communication.

Security risks:

1. Unencrypted communication: Standard HTTP does not encrypt transmitted information. Login credentials, session cookies, and other sensitive data may be exposed if transmitted over an untrusted network.
2. Web application vulnerabilities: Poorly developed applications may contain SQL injection, cross-site scripting (XSS), insecure file uploads, or authentication weaknesses.
3. Information disclosure: Server headers, error messages, directory listings, and exposed configuration files may reveal useful information about the application.
4. Outdated software: An unpatched web server or application framework may contain known vulnerabilities that attackers could exploit.
5. Session attacks: If session cookies are not adequately protected, an attacker may be able to steal or misuse a valid session.

Possible attack scenario: An attacker who can observe unencrypted traffic on a shared network may capture sensitive information transmitted through HTTP. Alternatively, an attacker may probe the web application for input-validation or access-control weaknesses.

Recommended security measures:

- Configure HTTPS using TLS and redirect HTTP requests to HTTPS.
- Use a valid digital certificate and secure TLS settings.

- Update the web server, application framework, and related components.
- Validate and sanitize user input to prevent injection attacks.
- Implement secure session management, including Secure, HttpOnly, and appropriate SameSite cookie attributes.
- Disable directory listing and remove unnecessary server information from responses.
- Deploy a Web Application Firewall (WAF) where appropriate.
- Conduct authorized web application security testing and remediate identified vulnerabilities.

Analysis: Port 80 is not automatically vulnerable simply because it is open. The main concern is whether sensitive communication is unencrypted or the web application exposes exploitable weaknesses. HTTPS and secure application development significantly reduce these risks.

4. Security Risks Associated with SSH (Port 22)

SSH (Secure Shell) is a protocol used for encrypted remote access and administration of computers and servers. It is commonly used by administrators to execute commands and manage systems remotely.

Security risks:

1. Brute-force attacks: Attackers may repeatedly attempt to guess weak usernames and passwords.
2. Credential compromise: Stolen passwords or private keys may allow unauthorized remote access.
3. Outdated SSH software: Older implementations may contain known security vulnerabilities.
4. Insecure configuration: Permitting unnecessary privileged logins, weak authentication methods, or excessive user permissions increases risk.
5. Unauthorized access: If a legitimate account is compromised, an attacker may misuse the account to inspect files, change configurations, or move further into the network.

Possible attack scenario: If SSH is accessible from the public internet and permits password-based login using weak credentials, an attacker may attempt repeated login guesses. Successful authentication could provide access to the account's permitted resources and potentially lead to further compromise if privileges are excessive.

Recommended security measures:

- Disable password authentication where practical and use strong SSH key-based authentication.
- Disable direct root login.
- Restrict SSH access to approved administrator IP addresses, VPNs, or management networks.
- Use multi-factor authentication where supported.
- Apply security updates to the SSH server and operating system.
- Follow the principle of least privilege by granting only the permissions required for each account.

Analysis: SSH provides encrypted communication, but encryption alone does not prevent unauthorized access. Strong authentication, restricted network exposure, appropriate permissions, and monitoring are necessary to secure remote administration.

5. Security Risks Associated with MySQL (Port 3306)

MySQL is a relational database management system used to store and manage structured information, including user accounts, application data, transactions, and business records. Port 3306 is its default TCP port.

Security risks:

1. Unauthorized database access: If the service is accessible from untrusted networks and authentication or access controls are weak, unauthorized users may attempt to connect.
2. Weak database credentials: Simple or reused passwords can increase the risk of account compromise.
3. Excessive privileges: Database accounts with unnecessary administrative permissions may allow unauthorized modification or deletion of information.

4. Sensitive data exposure: An improperly secured database may disclose personal information, credentials, or confidential business records.
5. SQL injection: A vulnerable web application may allow attackers to manipulate database queries through unsanitized input.

Possible attack scenario: If MySQL accepts connections from untrusted networks, an attacker may attempt to authenticate using compromised credentials or exploit a vulnerable database version. If access is obtained, the attacker may read, modify, or delete data according to the privileges of the compromised account.
A separate possibility is SQL injection through a vulnerable web application. In that case, the application—not merely the open database port—provides the initial attack path.
Recommended security measures:

- Do not expose MySQL directly to the public internet.
- Restrict port 3306 to approved application servers and administrator networks.
- Bind the database service to an appropriate private interface when remote access is unnecessary.
- Use strong, unique database passwords and remove default or unused accounts.
- Apply the principle of least privilege to database users
- Maintain encrypted, access-controlled backups and periodically test restoration.

Analysis: MySQL presents a potentially high-impact risk because a compromised database may expose or destroy sensitive information. Restricting network access and enforcing strong database privileges are essential controls.

6. Risks Associated with Operating System and Service Version Detection

Nmap may identify the target operating system and the versions of running services. This information helps security teams assess compatibility, verify patch levels, and identify obsolete components.
Potential risks include:

- Attackers using version information to identify publicly documented vulnerabilities.
- Targeted probing of services that appear outdated.
- Selection of exploits that match a particular operating system or service implementation.
- Identification of unsupported platforms that no longer receive security updates.

Recommended measures:

1. Verify detected versions against the installed software and vendor advisories.
2. Apply security patches and upgrade unsupported software.
3. Disable unused services and close unnecessary ports.
4. Conduct periodic authenticated vulnerability assessments.
5. Reduce unnecessary version disclosure where practical, without treating concealment as a substitute for patching.

7. Overall Security Recommendations

The following actions should be prioritized based on actual exposure and business impact.

Priority	Recommended action	Security benefit
High	Restrict MySQL port 3306 to trusted hosts	Reduces the risk of unauthorized database connections
High	Enforce HTTPS for web traffic	Protects information transmitted between clients and servers
High	Patch vulnerable or unsupported software	Addresses known software weaknesses

High	Strengthen SSH authentication and restrict access	Reduces unauthorized remote login risk
Medium	Apply least-privilege access controls	Limits the impact of compromised accounts
Medium	Configure centralized logging and alerts	Improves detection and investigation
Medium	Maintain secure backups and test recovery	Supports recovery from data loss or destructive attacks
Ongoing	Perform authorized security assessments	Identifies weaknesses before attackers exploit them

8. Conclusion

The Nmap report for 192.168.1.10 identifies HTTP, SSH, and MySQL services, together with operating system and service-version information. Each service has a legitimate operational purpose, but insecure configuration, outdated software, weak authentication, and excessive network exposure can introduce security risks.

HTTP should be protected with HTTPS and secure application controls. SSH should use strong authentication and restricted administrative access. MySQL should be isolated from untrusted networks, configured with least-privilege permissions, and protected against unauthorized access and SQL injection.

A comprehensive security strategy combines network segmentation, patch management, access control, encryption, logging, backups, and regular authorized testing. These measures reduce the likelihood of compromise and limit the damage if an incident occurs.

Question 2: Phishing Awareness Campaign Analysis Using GoPhish

1. Introduction

Phishing is a social engineering attack in which an attacker attempts to deceive users into revealing sensitive information, opening malicious files, transferring money, or performing other unauthorized actions. Phishing messages commonly impersonate trusted organizations, colleagues, managers, banks, or service providers.

GoPhish is a phishing simulation platform that can be used by authorized security teams to evaluate employee awareness and improve organizational defenses. A properly authorized simulation measures how employees respond to suspicious messages and helps identify weaknesses in security awareness and technical controls.

In this scenario, ABC Technologies Pvt. Ltd. conducted a phishing awareness campaign and observed that 40% of employees clicked a phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment.

These findings indicate that the organization should strengthen employee awareness, email protection, identity security, incident reporting, and response procedures.

2. Analysis of the GoPhish Report

Report finding	Security interpretation	Potential consequence
40% clicked the phishing link	Many employees interacted with a suspicious message	Exposure to fraudulent websites or further social engineering
20% entered login credentials	A significant proportion disclosed authentication information in the simulation	Possible account compromise if real credentials are stolen

Several users downloaded an attachment	Employees may not have adequately assessed attachment risks	Potential malware infection or execution if the file is malicious

The percentages must be interpreted using the campaign's actual denominator and event definitions. The report does not specify the total employee count, whether the 20% credential-entry figure is calculated from all recipients or only link-clickers, or whether the downloaded attachments were actually executed. Therefore, the findings demonstrate risky behavior in the simulation, but they do not by themselves prove that real accounts were compromised or that malware executed.

3. Analysis of Employees Clicking the Phishing Link

The 40% click rate indicates that a substantial proportion of employees interacted with the simulated phishing message.

Possible reasons for this behavior include:

1. Lack of awareness: Employees may not recognize suspicious links, misleading domains, or unexpected requests.
2. Urgency and fear: Messages claiming that an account will be suspended or a payment is overdue may encourage employees to act without verification.
3. Trust in familiar branding: Attackers may imitate legitimate company portals, cloud services, or business partners.
4. Insufficient link inspection: Employees may click shortened links or links whose displayed text differs from their actual destination.
5. Work pressure: Employees handling many emails may overlook warning signs when working quickly.

Potential security impact:

A malicious link may lead to a fake login page, a fraudulent payment request, or a website that attempts to exploit a vulnerable browser. A click does not automatically mean a device has been infected; the impact depends on the destination, browser security, and subsequent user actions.

Recommended measures:

- Train employees to inspect sender addresses, domains, and unexpected links.
- Encourage employees to navigate to official websites directly rather than using suspicious links.
- Deploy email link protection and domain reputation filtering.
- Establish an easy method to report suspicious messages.

Analysis: The click rate suggests a need for both improved employee judgment and stronger technical defenses. Organizations should not rely on awareness training alone to prevent phishing.

4. Analysis of Employees Entering Login Credentials

The report indicates that 20% of employees entered their credentials on the simulated phishing page. This is a more serious behavioral indicator because passwords and authentication information can provide access to corporate systems.

Security weaknesses demonstrated:

1. Failure to verify website authenticity: Employees may have trusted a fraudulent login page without checking the domain.
2. Weak credential-protection habits: Employees may not understand that credentials should never be entered through an unexpected email link.
3. Insufficient authentication resilience: If the organization relies only on passwords, stolen credentials may be sufficient to access accounts.
4. Limited use of phishing-resistant authentication: Some authentication methods are more resistant to credential phishing than traditional passwords or basic one-time codes.

5. Inadequate reporting behavior: Employees may fail to notify IT or security teams after realizing that credentials were entered into a suspicious website.

Potential attack scenario:
In a real attack, a fraudulent login page could collect a user's username and password. An attacker might then attempt to access corporate email, internal applications, or cloud services. If the account lacks adequate protection, the attacker may use it for further phishing, unauthorized data access, or privilege escalation.
Recommended measures:

- Implement multi-factor authentication (MFA), preferably phishing-resistant methods such as FIDO2 security keys or passkeys.
- Enforce unique passwords and use an approved password manager.
- Apply conditional access controls and least-privilege permissions.
- Monitor suspicious sign-ins, unusual locations, and abnormal account activity.
- Train employees to report credential disclosure immediately.
- Avoid collecting real employee passwords during simulations; record only the minimum behavioral data required.

Analysis: Credential entry represents a higher-risk action than merely clicking a link. Strong authentication, rapid reporting, and effective account-response procedures can reduce the likelihood and impact of credential theft.

5. Analysis of Employees Downloading Malicious Attachments

The report states that several employees downloaded a malicious attachment. This suggests that attachment-handling practices and email security controls require improvement.
Security weaknesses demonstrated:

1. Insufficient attachment inspection: Employees may trust files received from unknown or unexpected senders.
2. Failure to verify business requests: An attachment claiming to contain an invoice, resume, report, or delivery document may be accepted without checking its legitimacy.
3. Inadequate endpoint protection: If security software fails to detect a malicious file, additional controls may be needed.
4. Unsafe file-handling practices: Employees may enable macros, execute downloaded files, or bypass security warnings.
5. Insufficient email filtering: Suspicious attachments may reach employee inboxes without being blocked or quarantined.

Potential consequences:

- Malware infection or unauthorized execution of code.
- Theft of information or authentication tokens.
- Ransomware infection and file encryption.
- Unauthorized access to internal systems.
- Disruption of business operations and potential data loss.

Recommended measures:

- Deploy secure email gateways with attachment inspection.
- Use sandboxing or detonation services for suspicious files where appropriate.
- Apply endpoint detection and response (EDR) and updated anti-malware protection.
- Block unnecessary executable attachment types and risky file formats.
- Disable macros from untrusted sources and apply application-control policies.
- Keep operating systems, browsers, office applications, and PDF readers updated.
- Train employees to verify unexpected attachments through a separate trusted communication channel.

- Provide a procedure for reporting suspicious downloads and isolating affected endpoints when necessary.

Analysis: Attachment-based attacks require a layered defense because both employee mistakes and technical vulnerabilities can contribute to compromise. Email filtering, endpoint security, patching, and incident response should operate together.

6. Recommended User Awareness Programs

ABC Technologies should implement a continuous security awareness program rather than relying on a single training session.

A. Regular security awareness training

Training should explain common phishing techniques, fake login pages, suspicious attachments, impersonation, business email compromise, and safe handling of sensitive information.

B. Practical phishing simulations

Conduct periodic, authorized simulations using varied scenarios. Provide immediate educational feedback to employees who interact with simulated phishing content.

C. Role-based training

Employees in finance, human resources, administration, and IT may face different threats. Training should address the risks most relevant to their responsibilities.

D. Security awareness assessments

Use short quizzes, scenario-based exercises, and follow-up simulations to assess whether employees can recognize and respond to phishing attempts.

E. Positive reporting culture

Encourage employees to report suspicious messages without fear of unfair punishment for honest mistakes. Prompt reporting helps security teams block threats before other employees are affected.

F. Clear reporting instructions

Teach employees how to use the organization's phishing-report button or designated security contact. Explain what to do if a link was clicked, credentials were entered, or a file was opened.

7. Recommended Email Security Controls

Control	Purpose
Secure Email Gateway	Filters spam, phishing messages, and suspicious attachments
SPF	Helps receiving systems verify whether sending servers are authorized for a domain
DKIM	Uses cryptographic signatures to help verify message integrity and domain association
DMARC	Defines how receiving systems should handle messages that fail relevant domain-authentication checks
URL Filtering	Blocks access to known malicious or suspicious websites
Attachment Sandboxing	Analyzes suspicious files in an isolated environment
EDR and Anti-malware	Detects and helps respond to malicious activity on endpoints
MFA and Passkeys	Reduce the risk of unauthorized account access after password exposure
Security Monitoring	Detects suspicious login activity and other indicators of compromise

8. Recommended Organizational Policies

ABC Technologies should establish clear, documented policies covering the following areas.
1. Email and internet usage policy: Define safe email practices, prohibited activities, and procedures for handling suspicious links and attachments.
2. Password and authentication policy: Require strong, unique credentials, MFA for important systems, and secure recovery processes.
3. Incident reporting policy: Require prompt reporting of suspected phishing, credential disclosure, suspicious downloads, and unauthorized account activity.
4. Access control policy: Apply least privilege, review access rights periodically, and remove access when employees change roles or leave the organization.
5. Endpoint security policy: Require supported operating systems, regular updates, endpoint protection, and approved software installation.

9. Measuring the Effectiveness of Improvements

The organization should compare subsequent simulations with the baseline report and monitor trends over time.
Useful metrics include:

- Phishing click rate.
- Credential-submission rate.
- Attachment download and execution rates, measured separately.
- Percentage of employees reporting simulated phishing messages.
- Time taken to report suspicious messages.
- Repeat interaction rates among training participants.
- Number of real phishing incidents detected and successfully contained.

A lower click or credential-submission rate may indicate improvement, while a higher reporting rate can indicate stronger awareness. Results should be interpreted alongside campaign difficulty, employee roles, reporting opportunities, and technical defenses rather than treated as standalone proof of security.

10. Conclusion

The GoPhish report for ABC Technologies Pvt. Ltd. reveals important opportunities to improve phishing awareness and organizational security. The 40% click rate indicates that many employees interacted with the simulated phishing message, the 20% credential-entry rate highlights the need for stronger protection against credential theft, and attachment downloads identify a need for safer file-handling practices.
To address these weaknesses, the organization should combine regular awareness training, realistic phishing simulations, secure email gateways, SPF/DKIM/DMARC, attachment sandboxing, endpoint protection, MFA, and effective incident response.
A successful anti-phishing strategy requires both informed employees and resilient technical controls. By measuring results, providing constructive feedback, and continuously improving security procedures, ABC Technologies can reduce its exposure to social engineering attacks and strengthen its overall security posture.

Question 3: DN Zone Transfer (AXFR) Vulnerability

1. Introduction

The Domain Name System (DNS) translates domain names into IP addresses and provides other information required for network communication. DNS records identify services such as web servers, mail servers, and other network resources.
A DNS zone contains records associated with a domain. A DNS Zone Transfer, commonly called AXFR, allows an authorized secondary DNS server to obtain a copy of a zone from the primary server.

Zone transfers are necessary for some DNS architectures. However, if a DNS server allows unauthorized clients to perform AXFR, it may disclose a large amount of information about the organization's infrastructure.
In this scenario, the Dig assessment indicates that the DNS server permits a successful zone transfer and exposes internal hostnames, mail servers, and DNS records. This suggests that the zone-transfer access controls may be incorrectly configured.

2. Analysis of the DNS Assessment Report

The dig utility is a DNS troubleshooting and diagnostic tool. Security analysts can use it to inspect DNS records and, when authorized, verify whether a DNS server permits zone transfers.
An authorized test can use the following command:
dig @<DNS_SERVER_IP> <DOMAIN_NAME> AXFR
Replace <DNS_SERVER_IP> and <DOMAIN_NAME> with the approved DNS server and domain. The command should only be run against infrastructure for which testing is authorized.
If the transfer succeeds for an unauthorized client, the server may return records from the requested DNS zone. The exact information exposed depends on the contents of that zone.
The scenario specifically identifies three categories of exposed information:

- Internal hostnames.
- Mail server details.
- Other DNS records.

3. Security Implications of Exposed DNS Information

A. Exposure of internal hostnames
Internal hostnames may reveal server roles, department names, development environments, or administrative systems. For example, names indicating development, backup, VPN, or management services may disclose the purpose of a system.
Risk: Attackers could use these names to identify potentially sensitive systems and prioritize further reconnaissance.
B. Exposure of mail server information
DNS records such as MX records identify mail servers responsible for receiving messages for a domain. Related records may reveal mail infrastructure and service providers.
Risk: Attackers could use this information to tailor phishing campaigns, impersonate business communication, or investigate the organization's email configuration.
C. Exposure of service and infrastructure records
DNS records may identify application servers, subdomains, test environments, and other network services.
Risk: An attacker may build a more complete map of the organization's externally visible infrastructure and look for outdated services, misconfigured systems, or weak access controls.
D. Information disclosure and reconnaissance

4. How Attackers Could Exploit the Findings

The exposed information could support several stages of an attack:

1. Reconnaissance: An attacker collects hostnames, mail servers, subdomains, and other records to understand the organization's infrastructure.
2. Target identification: The attacker identifies systems that appear to support sensitive functions, such as administration, development, or remote access.
3. Targeted phishing: Exposed organizational and mail-server information may help an attacker create more convincing messages.

4. Further vulnerability assessment: Identified hosts may be investigated for outdated software or insecure configurations, subject to the attacker's access and the systems' exposure.
5. Attack planning: The collected information may help prioritize potential entry points and prepare more targeted attempts.

These activities describe the potential misuse of exposed information, not proof that any of the identified systems have been compromised.

5. Recommended Measures to Secure DNS Infrastructure

A. Restrict DNS Zone Transfers

Configure the authoritative DNS server to allow AXFR only to explicitly authorized secondary DNS servers. Deny transfers to all other clients.

B. Apply Access Control Lists

Use DNS server access control lists to specify which IP addresses may request zone transfers. Review these rules periodically and remove outdated entries.

C. Use TSIG Authentication

Transaction Signature (TSIG) can authenticate and protect the integrity of supported DNS transactions between primary and secondary servers. Configure it where supported and required by the DNS architecture.

D. Separate Internal and External DNS

Use split-horizon DNS or appropriately separated internal and public zones to prevent private hostnames and records from being unnecessarily exposed to external clients.

E. Review DNS Records

Remove obsolete records, unused subdomains, and unnecessary information. Ensure that public DNS zones contain only records intended for public disclosure.

F. Update DNS Software

Keep DNS server software patched and use vendor-recommended secure configurations. Disable unnecessary services and management interfaces.

6. Verification and Remediation

After applying the changes, an authorized security analyst should verify the configuration using approved testing methods.

- Confirm that legitimate secondary DNS servers can still obtain the required zone data.
- Confirm that unauthorized clients cannot perform AXFR.
- Review DNS server logs to verify that unexpected transfer attempts are denied or appropriately recorded.
- Check that internal-only records are not published in public DNS zones.
- Document the original finding, remediation steps, verification results, and any remaining risks.

The objective is to prevent unauthorized information disclosure without disrupting legitimate DNS replication.

7. Conclusion

The DNS assessment report indicates that the organization's DNS server permits a successful AXFR zone transfer, exposing internal hostnames, mail servers, and DNS records. This configuration can provide attackers with valuable information for reconnaissance, target identification, and targeted social engineering.

The organization should restrict zone transfers to authorized secondary servers, implement appropriate access controls and TSIG authentication where supported, separate internal and public DNS data, update DNS software, and monitor suspicious requests.

Regular DNS security audits and post-remediation verification are essential to ensure that zone transfers remain available to legitimate systems while unauthorized information disclosure is prevented.

OVERALL CONCLUSION

Ethical hacking plays a vital role in identifying security vulnerabilities, analyzing potential threats, and protecting organizational information systems from cyberattacks. This assessment examined three important cybersecurity areas: network scanning using Nmap, phishing awareness analysis using GoPhish, and DNS security assessment using the Dig tool.

The Nmap report analysis demonstrated how open ports, running services, and software-version information can reveal potential security risks. Securing HTTP through HTTPS, strengthening SSH authentication, restricting MySQL access, and applying regular security updates can significantly reduce the attack surface.

The GoPhish report analysis highlighted the importance of employee awareness in preventing social engineering attacks. Phishing simulations, regular security training, multi-factor authentication, email filtering, endpoint protection, and effective incident-reporting procedures can reduce the risk of credential theft and malware infection.

The DNS assessment demonstrated that unauthorized DNS Zone Transfers (AXFR) may expose internal hostnames, mail servers, and other DNS records. Restricting zone transfers, implementing appropriate access controls, separating internal and public DNS records, and monitoring DNS activity can help prevent information disclosure.

References:

1. Nmap Project. Nmap Reference Guide and Official Documentation. Available at: https://nmap.org/docs.html

2. GoPhish. GoPhish: Open-Source Phishing Framework. Available at: https://getgophish.com/

3. OWASP Foundation. OWASP Top 10: Web Application Security Risks, 2025. Available at: https://owasp.org/Top10/2025/

4. Cybersecurity and Infrastructure Security Agency (CISA). Phishing: General Security Tips. Available at: https://www.cisa.gov/sites/default/files/2024-02/Update%20to%20Phishing%20General%20Security%20Postcard_01.01.2024.pdf

5. Internet Systems Consortium (ISC). BIND 9 Administrator Reference Manual. Available at: https://bind9.readthedocs.io/en/stable/reference.html

6. Internet Systems Consortium (ISC). An Overview of BIND 9 Documentation. Available at: https://kb.isc.org/docs/aa-01031